

Bachelor's Thesis Proposal

Modeling and Enforcing Shared Ownership of Personal Data

Assessor: Dr. Hoang Nguyen
Co-assessor: To be decided

1 Motivation

Ensuring that software systems, especially web applications, comply with privacy requirements is a complex and critical challenge. On the one hand, it is complex because laws, such as the GDPR [1], impose strict requirements on how organizations handle (personal) data but offer limited guidance on concrete technical solutions. On the other hand, it is critical because failing to comply with these requirements can result in substantial financial penalties.

Model-driven privacy [2] (MDP) is a software development methodology in which privacy requirements are specified as models, and enforcement mechanisms are generated automatically via model transformations. MDP enables developers to specify three interconnected declarative models: a data model describing the state space of the system, a security model capturing fine-grained access control requirements, and a privacy model expressing data protection requirements, which is a particularly challenging class of privacy requirements. From these models, the methodology automatically generates a web application together with enforcement mechanisms that make it security- and privacy-aware by design.

2 Objective

A central concept in MDP is the *owner* of a piece of personal data: the data subject to whom the data pertains and whose consent and data subject rights govern how it may be used. The current MDP approach assumes that each datum has a *single* owner.

In practice, however, a single item of personal data often pertains to several data subjects at once, e.g., a photo depicting multiple people, a shared address, a joint account, or a message exchanged between two parties. A single-owner model cannot express such shared ownership, so the access control and consent decisions derived from it can be incorrect. For example, consider the following scenario: "Alice tags Bob in a group photo. Bob withdraws consent. Can the app still show the photo to Alice's friends?"

In this thesis, we extend the model to allow a single item of personal data to have multiple co-owners.

3 Tasks

1. Study the existing MDP approach.
2. Design a conceptual extension for shared ownership, modeling ownership as a relation among multiple data subjects.
3. Define the semantics for access and consent decisions among co-owners.
4. Realize the extension in the MDP modeling language and its enforcement.
5. Validate the extended approach in a case-study application.
6. Document the design, implementation, and evaluation in the final report.

4 Deliverables

The following deliverables are due at the end of the project:

Final report Please have a look at the submission requirements in the following section. The final report should consist of an introduction, a (theoretical) background section, sections describing the work packages and their outcomes, and a conclusion. The report must be written in English.

Source code Complete, documented source code with a reproducible evaluation.

Presentation At the end of the thesis, a 20-minute presentation must be given in a thesis defense seminar. It should give an overview and discuss the most important highlights of the work.

References

- [1] European Parliament and Council. Regulation (EU) 2016/679, 2016. <https://eur-lex.europa.eu/eli/reg/2016/679/oj>.
- [2] Srdan Krstic, Hoang Nguyen, and David Basin. Model-driven privacy. *Proc. Priv. Enhancing Technol.*, 2024(1):314–329, 2024.